

API Reference

Base URL: `http://localhost:4000`. All requests and responses are JSON. Errors return `{ "error": "message" }`.

Auth

POST /auth/login

Demo login: finds a user by name. No password check.

Request: `{ "name": "Alice" }` Response: `{ "token": "demo-token", "user": { "id": 1, "name": "Alice", "role": "admin" } }` Errors: 400 name missing, 404 user not found.

Access

POST /access/grant

Admin only. Inserts into `permissions` and appends a ledger event.

Request:

```
{ "user_id": 2, "resource_id": 1, "access_type": "read", "granted_by": 1 }
```

Response: `{ "permission": { ... }, "ledgerEvent": { ... } }`. The ledger `action` is `grant:read`. Errors: 400 missing fields, 403 `granted_by` is not an admin, 500 (including duplicate `(user_id, resource_id, access_type)`).

POST /access/revoke

Admin only. Deletes all of the user's permissions on the resource and appends a `revoke` ledger event.

Request: `{ "user_id": 2, "resource_id": 1, "revoked_by": 1 }` Response: `{ "ledgerEvent": { ... } }` Errors: 400 missing fields, 403 not an admin, 404 no matching permission.

GET /access/list

Returns all current rows from `permissions` as an array.

Ledger

GET /ledger

Returns all `ledger_events` ordered by `id` ascending.

```
[{
  "id": 1,
  "prev_hash": "000...000",
  "event_hash": "9f2c...",
  "actor_id": 1,
  "resource_id": 1,
  "action": "grant:read",
  "created_at": "2026-09-24T09:15:00.000Z"
}]
```

Audit

GET /audit/verify

Recomputes the whole chain and reports every event that doesn't match.

Response: `{ "valid": false, "brokenAt": [3] }`. An intact (or empty) ledger returns `{ "valid": true, "brokenAt": [] }`.

Not implemented

`GET /users` and `GET /resources` do not exist yet. The client falls back to the names in `client/lib/directory.js`.